

UF1

Aplicación de medidas de seguridad pasiva

Ciberseguridad

ÍNDICE

Introducción.....	04
Objetivos.....	05
Mapa conceptual	06
1. Introducción a la seguridad.....	07
1.1. Mantener la información segura	07
1.2. Tipos de seguridad pasiva	09
A. Seguridad física	09
B. Seguridad lógica	10
2. Seguridad física	12
2.1. Ubicación del CPD	12
2.2. Control de accesos.....	15
2.3. Condiciones ambientales	17
2.4. Plan de recuperación de desastres	19
3. SAI	22
3.1. Tipos de SAI	23
A. SAI fuera de línea	24
B. SAI online.....	25
C. SAI inline.....	25
3.2. Monitorización.....	26
3.3. Triggers.....	27
3.4. Mantenimiento	28

4. Seguridad lógica	31
4.1. Política de seguridad basada en listas de control	
de acceso (ACL)	31
A. Definición de roles y privilegios	31
B. Control de recursos.....	32
C. Principios fundamentales	32
D. Implementación técnica.....	32
E. Reglas y políticas de acceso	33
F. Auditorías y monitoreo	33
4.2. Política de contraseñas.....	34
4.3. Utilización de sistemas biométricos	36
A. Alta seguridad.....	36
B. Reducción de problemas asociados a las contraseñas.....	36
C. Conveniencia y rapidez	37
D. Dificultad para transferir o compartir	37
E. Compatibilidad con autenticación multifactor	37
F. Registro y auditoría fiables	37
G. Longevidad y durabilidad	37
H. Aplicaciones versátiles	38
I. Adaptación a contextos modernos	38
Solucionario casos prácticos	40
Enlaces de interés	45
Glosario	46
Bibliografía	48

Introducción

La confidencialidad, la integridad y la disponibilidad son los principios de la seguridad informática. ¿Te has preguntado en qué consisten? ¿Cómo se garantizan? ¿Sabes cuál es la diferencia entre seguridad física y seguridad lógica? Deberás aprender a analizar riesgos y amenazas relacionados con ambos tipos. Esto te permitirá, en tu rol de especialista en seguridad informática, identificar vulnerabilidades y proponer soluciones adecuadas según las necesidades y recursos disponibles.

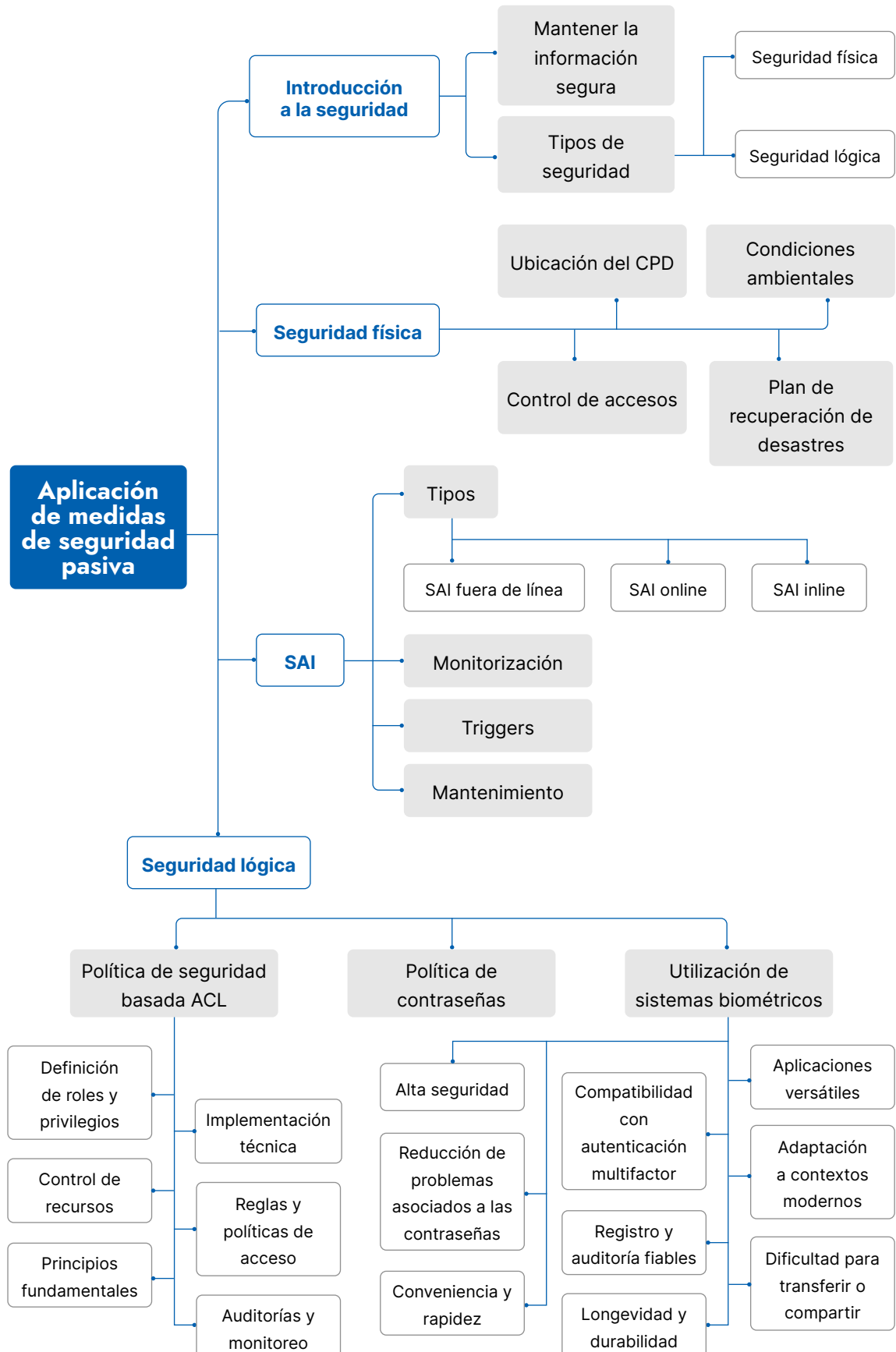
Por otra parte, estudiarás los tipos de amenazas y riesgos en sistemas informáticos, como el malware, los ataques DDoS, el phishing y el ransomware, entre otros. Como miembro de un departamento de ciberseguridad, te pedirán rapidez y eficacia a la hora de resolver problemas relacionados con accesos no autorizados y actualización de medidas de seguridad. ¿Sabrías diseñar planes de contingencia y recuperación ante desastres o mantener entornos controlados y seguros, como en el caso de los centros de procesamiento de datos? Tanto si eres técnico de soporte, y debes configurar sistemas seguros, como si te conviertes en auditor de seguridad, en cuyo caso te encargarás de la supervisión de los controles, deberás estar preparado para afrontar las eventualidades, conocer su naturaleza y aplicar planes DRP.

Además, aprenderás a manejar nuevas tecnologías y herramientas y a gestionar recursos. Esto te permitirá saber cómo priorizar la implementación de proyectos dentro de un presupuesto definido, lo cual es fundamental si asumes responsabilidades directivas en tu organización o en un CPD.

Objetivos

- X | Conocer la importancia de mantener la información segura e identificar las diferencias entre seguridad física y lógica.
- X | Ser capaz de definir las características óptimas de la ubicación física, las condiciones ambientales y la protección física para un CPD.
- X | Distinguir entre los diferentes tipos de SAI y ser capaz de seleccionar los más adecuados en función del contexto.
- X | Conocer las características de la política de seguridad de ACL y de contraseñas y valorar el uso de sistemas biométricos de control de acceso.

Mapa conceptual



01 Introducción a la seguridad

1.1. Mantener la información segura

La información es **uno de los activos más valiosos en el mundo actual**. Su adecuada protección asegura la confidencialidad, la integridad y la disponibilidad de los datos, lo que impacta directamente en la estabilidad operativa de personas, empresas y gobiernos. Por eso hemos de tener en cuenta los siguientes conceptos en lo que al acceso a la información se refiere:

Protección contra accesos no autorizados

El acceso no autorizado puede poner en peligro información sensible como contraseñas, datos financieros, estrategias empresariales y documentos confidenciales. Mantener la información segura evita:

- Fugas de datos personales que pueden llevar a robos de identidad.
- Exposición de secretos empresariales, lo que afecta a la competitividad.
- Amenazas a la seguridad nacional, en casos de espionaje cibernético.

Confidencialidad

La confidencialidad asegura que solo las personas o sistemas autorizados puedan acceder a la información. Es clave en:

- Entornos personales: proteger conversaciones privadas, fotografías y datos de salud.
- Negocios: garantizar que contratos, investigaciones y acuerdos no sean vulnerados.
- Sector público: salvaguardar datos ciudadanos y operaciones gubernamentales sensibles.

Prevención de fraudes y pérdidas económicas

El robo de información puede resultar en pérdidas financieras masivas. Algunos ejemplos incluyen:

- **Fraude financiero:** clonación de tarjetas, transferencias no autorizadas y phishing.
- **Ransomware:** secuestro de datos a cambio de pagos, impactando en empresas y usuarios.
- **Daños indirectos:** pérdida de reputación y de confianza de los clientes.

Integridad de los datos

La integridad asegura que los datos no sean alterados de manera accidental o maliciosa. Esto es esencial para:

- **Empresas:** garantizar la calidad de los procesos operativos y la toma de decisiones.
- **Gobiernos:** asegurar que los registros, los censos y los sistemas electorales no sean manipulados.

Cumplimiento normativo y legal

Existen leyes y normas que exigen medidas de protección de la información, como la LOPD (Ley Orgánica de Protección de Datos) en España y otras normativas globales. El incumplimiento puede acarrear:

- Multas millonarias.
- Pérdida de credibilidad.
- Posibles demandas legales.

Disponibilidad operativa

La disponibilidad asegura que los datos y sistemas estén accesibles cuando se necesiten. Esto es crucial para:

- **Negocios:** garantizar operaciones continuas, evitando interrupciones en servicios críticos.
- **Hospitales:** proveer acceso a historiales médicos en situaciones de emergencia.
- **Servicios públicos:** mantener operativas infraestructuras como las redes eléctricas y de telecomunicaciones.

Prevención de ataques cibernéticos

El número y la sofisticación de los ataques cibernéticos han aumentado drásticamente. La seguridad de la información ayuda a prevenir:

- **Ataques DDoS:** saturación de redes y servicios.
- **Malware y spyware:** programas diseñados para robar información o causar daños.

Reputación y confianza

Tanto a nivel personal como organizacional, la pérdida de información puede dañar gravemente la confianza:

- **En empresas:** los clientes pueden dudar en compartir información si no confían en las medidas de seguridad.
- **En gobiernos:** las filtraciones de datos pueden desestabilizar la confianza ciudadana.

**WEB**

Importancia de la seguridad de la información:

<https://www.incibe.es/empresas/blog/pasado-presente-y-futuro-de-la-seguridad-de-la-informacion>

1.2. Tipos de seguridad pasiva

La seguridad física y la seguridad lógica son dos pilares fundamentales dentro de la seguridad informática.

A. Seguridad física

Se refiere a la protección de los equipos, dispositivos y recursos informáticos contra **daños físicos, robos, desastres naturales** u otros eventos que puedan comprometer su integridad. Un ejemplo de ello sería proteger un servidor en un CPD contra incendios o accesos no autorizados.

Objetivos

- Evitar daños físicos en los equipos y dispositivos.
- Prevenir el acceso no autorizado a áreas restringidas, como centros de datos o salas de servidores.
- Minimizar el impacto de eventos catastróficos (incendios, inundaciones, etc.).
- Asegurar la protección de la infraestructura en entornos de computación en la nube y ubicaciones remotas.

Medidas

- **Accesos controlados:** cerraduras biométricas, cámaras de vigilancia, tarjetas RFID.
- **Protección contra desastres:** sistemas contra incendios, suelos elevados, sistemas de climatización.
- **Protección de equipos:** uso de racks, cajas fuertes y dispositivos de protección contra picos eléctricos (SAI/UPS).
- **Seguridad en la nube:** implementación de centros de datos seguros con redundancia geográfica, control de acceso a servidores remotos y protección contra interrupciones en la conectividad.
- **Control de acceso a entornos remotos:** uso de redes privadas virtuales (VPN) y herramientas de acceso seguro para empleados y usuarios externos.

Amenazas contra las que protege

- Robos o sabotajes.
- Desastres naturales, como terremotos e inundaciones.
- Fallos en la infraestructura, como apagones e incendios.
- Pérdida de acceso a servidores en la nube por falta de redundancia o protección.

B. Seguridad lógica

Implica la protección de los datos y sistemas informáticos mediante herramientas y configuraciones diseñadas para **prevenir accesos no autorizados, alteraciones o pérdidas de información digital**. Un ejemplo es la implementación de contraseñas seguras y sistemas de cifrado.

Objetivos

- Proteger la confidencialidad, la integridad y la disponibilidad de la información digital.
- Prevenir ataques cibernéticos como el malware, el phishing o el hacking.
- Garantizar que solo usuarios autorizados accedan a los sistemas y datos sensibles.

Medidas

- **Autenticación:** contraseñas, biometría, autenticación multifactor (MFA).
- **Cifrado de datos:** protección de información sensible durante la transmisión y el almacenamiento.
- **Control de acceso:** configuración de permisos según roles y necesidades específicas.
- **Sistemas de monitorización:** firewalls, antivirus, IDS/IPS (sistemas de detección y prevención de intrusos).

Amenazas contra las que protege

- Ataques cibernéticos (phishing, ransomware y DDoS).
- Vulnerabilidades en software y sistemas operativos.
- Acceso indebido a datos confidenciales por falta de control en los permisos.

De esta manera, mientras la seguridad física asegura que los dispositivos estén operativos y protegidos frente a amenazas externas, la seguridad lógica se encarga de que los datos procesados por estos dispositivos estén resguardados frente a accesos no autorizados o alteraciones digitales. Ambas son esenciales para mantener la seguridad completa de una organización.

1 CASO PRÁCTICO



IDENTIFICACIÓN DE TAREAS PROPIAS DE LA SEGURIDAD FÍSICA Y LA SEGURIDAD LÓGICA

A continuación, se proporciona una lista de tareas que se han de implementar en un sistema informático. Hay que clasificarlas según correspondan a la seguridad física o a la seguridad lógica en una tabla como la que sigue:

SEGURIDAD FÍSICA	SEGURIDAD LÓGICA

Tareas:

- | | |
|----------------------------------|-------------------------------------|
| » Protección contra incendios. | » Autenticación biométrica. |
| » Instalación de falso techo. | » Autenticación multifactor. |
| » Sistema de videovigilancia. | » Control de permisos por ACL. |
| » Protección de equipos con SAI. | » Antivirus. |
| » Sistema de climatización. | » Permisos de carpetas compartidas. |

02 Seguridad física

La seguridad física garantiza la protección de los sistemas informáticos frente a amenazas externas y condiciones adversas. Incluye medidas preventivas, controles y planes de acción diseñados para evitar daños, accesos no autorizados y pérdidas de datos.

2.1. Ubicación del CPD

Los servidores que están funcionando en una empresa se ubican todos juntos en una misma sala. Esta sala tiene varios nombres: CPD (centro de procesamiento de datos), centro de cálculo, data center, etc.

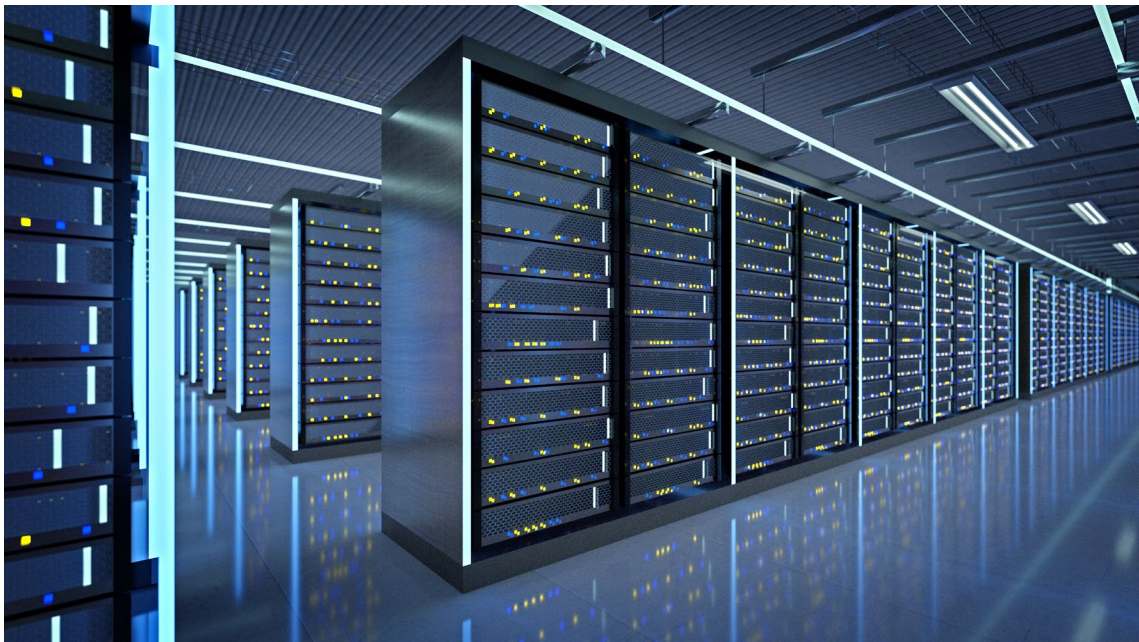


Fig. 1. Centro de procesamiento de datos.



¿SABÍAS QUE...?

El término **CPD** (centro de procesamiento de datos) evolucionó desde su primera denominación, que era centro de cálculo, debido a que la primera utilidad de los ordenadores fue realizar cálculos.

Centralizando los servidores se consigue:

- » **Ahorrar en costes de protección y mantenimiento:** No necesitan que se duplique la vigilancia, la refrigeración, etc.
- » **Optimizar las comunicaciones entre servidores:** Al estar unos cerca de otros, no necesitan utilizar cables largos o demasiados elementos intermedios que reducen el rendimiento.
- » **Aprovechar mejor los recursos humanos del departamento de informática:** Los profesionales no tienen que desplazarse a distintos edificios para realizar instalaciones, sustituir tarjetas, etc.

El CPD debe estar **protegido al máximo** y ello se llevará a cabo a través de las siguientes medidas:

- » Elegiremos un edificio en una zona con baja probabilidad de accidentes naturales (terremotos, ciclones, inundaciones).
- » Evitaremos la proximidad de ríos, playas, presas, aeropuertos, autopistas, bases militares, centrales nucleares, etc.
- » También evitaremos ubicaciones en las que los edificios vecinos al nuestro pertenezcan a empresas dedicadas a actividades potencialmente peligrosas: gases inflamables, explosivos, etc.
- » Preferentemente, seleccionaremos la **primera planta** del edificio, ya que:
 - La planta baja está expuesta a sabotajes desde el exterior (impacto de vehículos, asaltos, etc.).
 - Las plantas subterráneas serían las primeras afectadas por una inundación.
 - Las plantas superiores están expuestas a un accidente aéreo y, en caso de incendio iniciado en plantas inferiores, es seguro que quedarán afectadas.
- » Se recomienda que el edificio tenga dos accesos y por calles diferentes. Así siempre podremos entrar en caso de que una entrada quede inaccesible (obras, incidente, etc.).
- » Es recomendable evitar señalar la ubicación del CPD para dificultar su localización a posibles atacantes. La lista de empleados que entran a esta sala es muy reducida y saben perfectamente dónde está.
- » En las paredes de la sala se deberá utilizar pintura plástica, porque facilita su limpieza y evita la generación de polvo.
- » En la sala se utilizará falso suelo y falso techo, porque facilita la distribución del cableado (para electricidad y comunicaciones) y la ventilación.

- » La altura de la sala será elevada, tanto para permitir el despliegue de falso suelo y falso techo como para acumular muchos equipos en vertical, porque el espacio de esta sala es muy valioso.



Fig. 2. Falso techo.

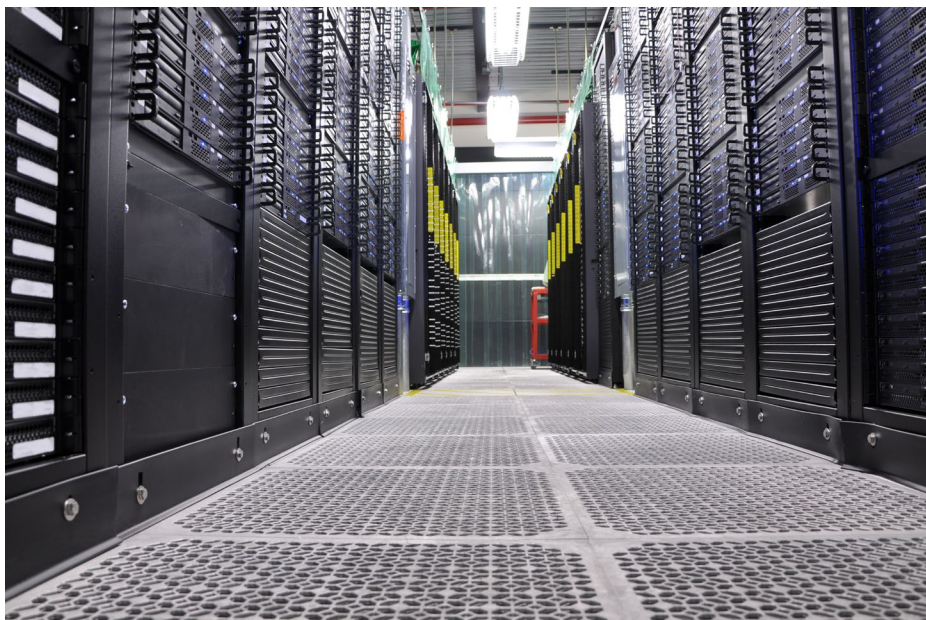


Fig. 3. Falso suelo.

- » En empresas de alta seguridad, la sala del CPD se recubre con un cofre de hormigón para protegerla de intrusiones desde el exterior.
- » Instalaremos equipos de detección de humos y sistemas automáticos de extinción de incendios.
- » El mobiliario de la sala debe estar fabricado con materiales ignífugos.

2.2. Control de accesos

El **control de accesos en un CPD** es un aspecto crítico para garantizar la seguridad física y la protección de los activos tecnológicos más importantes de la empresa. Los servidores, las estaciones de almacenamiento y los dispositivos de red que se encuentran en estas salas son esenciales para las operaciones empresariales, por lo que solo un grupo muy reducido de especialistas debe tener acceso autorizado. Esto incluye a técnicos, administradores de sistemas y personal encargado de la supervisión de los equipos.

Permitir el acceso a personas no autorizadas pone en riesgo no solo los dispositivos, sino también la confidencialidad, la integridad y la disponibilidad de la información almacenada. Por ello, el acceso físico a la sala debe estar **estrictamente restringido** para evitar cualquier posibilidad de robo o manipulación no autorizada de equipos o componentes, como discos duros, cintas de respaldo o incluso periféricos. Además, es fundamental proteger las consolas de los servidores, ya que estas permiten interacciones directas con los sistemas críticos. Un acceso no controlado podría derivar en sabotajes, instalaciones de malware o incluso filtraciones de datos sensibles.

Para lograr este nivel de seguridad, los métodos tradicionales, como las contraseñas y las tarjetas de acceso, se complementan con tecnologías avanzadas. Una de las medidas más eficaces es el uso de **sistemas de biometría**, como lectores de huellas dactilares, escáneres de retina o reconocimiento facial. Estas tecnologías garantizan que únicamente las personas autorizadas, cuya identidad ha sido verificada de manera única e intransferible, puedan ingresar al CPD.

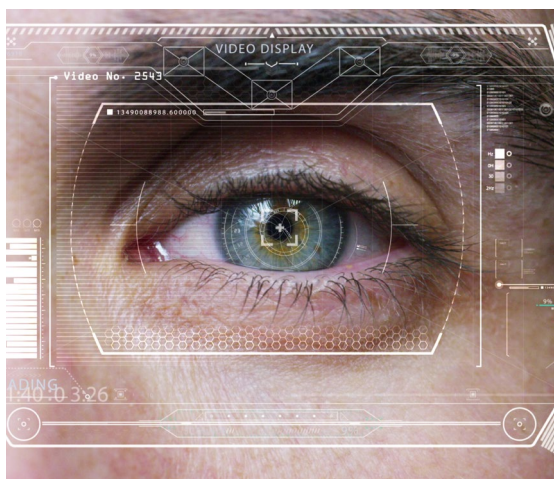


Fig. 4. Escáner de retina.



Fig. 5. Lector de huellas.

Adicionalmente, se puede implementar una **red de sensores de presencia y cámaras de videovigilancia** que permiten monitorear toda la actividad dentro y fuera de la sala. Estos sistemas no solo graban imágenes y detectan movimientos, sino que también pueden integrarse con alarmas que se activan en caso de intentos de intrusión. Muchas de estas cámaras están conectadas a un sistema centralizado que permite a los responsables de seguridad supervisar en tiempo real las operaciones y responder inmediatamente ante cualquier incidente.



Fig. 6. Detección.

En los CPD más avanzados, estas medidas de seguridad se complementan con **controles de acceso por capas**. Por ejemplo, además de un control biométrico inicial, puede ser necesario validar nuevamente la identidad del usuario para acceder a zonas específicas dentro del CPD, como los racks de servidores o las áreas de almacenamiento de datos sensibles.



WEB

Medidas implementadas por Microsoft para proteger sus centros de datos, incluyendo el uso de tarjetas de acceso y lectores biométricos supervisados a través de sistemas de alarma: <https://learn.microsoft.com/es-es/compliance/assurance/assurance-datacenter-physical-access-security>

2.3. Condiciones ambientales



¿SABÍAS QUE...?

En los CPD, las **condiciones ambientales** juegan un papel crucial en la operatividad y la conservación de los equipos informáticos. La estabilidad de factores como la temperatura, la humedad y la calidad del aire es esencial para garantizar el correcto funcionamiento de los servidores y los dispositivos de red, ya que cualquier desequilibrio puede provocar fallos técnicos, daños físicos o incluso la pérdida de datos.

Uno de los elementos más importantes que debemos considerar es la **temperatura**. Los equipos informáticos, especialmente los servidores, generan grandes cantidades de calor debido a su operación continua. Por ello, se requiere un control preciso de la temperatura para evitar el sobrecalentamiento, que podría llevar a interrupciones o averías permanentes. El rango óptimo de temperatura en un CPD suele estar entre los 18 y 24 °C, ya que esta franja asegura un entorno estable para los dispositivos. Para mantener estas condiciones, se utilizan sistemas de climatización especializados que no solo enfrían el aire, sino que también gestionan su distribución de manera eficiente.

Un diseño común en los CPD es el uso de **pasillos fríos y calientes**, método que consiste en organizar los racks de servidores en filas alternas, maximizando así la entrada de aire frío y la extracción de aire caliente. Este método optimiza el uso de la climatización y previene puntos calientes que podrían comprometer los equipos.

La **humedad relativa** es otro factor crítico. Una humedad muy baja aumenta el riesgo de acumulación de electricidad estática, que puede dañar los componentes electrónicos, mientras que una humedad alta favorece la corrosión de los circuitos y otros elementos metálicos. El rango adecuado de humedad se sitúa entre el 40 y el 60 %, lo que asegura un entorno equilibrado para los equipos. Para lograrlo, es común instalar sistemas de deshumidificación o humidificación, dependiendo de las necesidades específicas del entorno. Además, se utilizan sensores para monitorear continuamente los niveles de humedad y garantizar que se mantengan dentro de los límites establecidos.

Otro aspecto que debemos considerar es el **control del polvo y de las partículas suspendidas en el aire**, que pueden bloquear los sistemas de ventilación y reducir la eficiencia de los equipos, causando sobrecalentamiento y desgaste prematuro. Para evitar este problema, los CPD están equipados con filtros de aire de alta eficiencia (HEPA) que eliminan partículas del aire. Además, se aplican estrictas normas de limpieza en las instalaciones para evitar la acumulación de polvo y, en muchos casos, se implementan sistemas de presión positiva para impedir que el polvo ingrese desde el exterior.

Finalmente, los CPD deben estar preparados para enfrentar riesgos ambientales externos, como **incendios o inundaciones**. En el caso de los incendios, se instalan detectores de humo sensibles y sistemas de extinción con gases inertes como el FM-200 o el CO₂, que son efectivos para apagar las llamas sin dañar los equipos electrónicos. Respecto a las inundaciones, se evita ubicar los CPD en sótanos o áreas propensas a la acumulación de agua, y los racks se colocan sobre plataformas elevadas para protegerlos en caso de filtraciones o fugas.



Fig. 7. Detectores de humo.

Mantener estas condiciones ambientales no solo protege los equipos, sino que también extiende su vida útil, optimiza su rendimiento y garantiza la continuidad operativa de los servicios que dependen de ellos. Por ello, el diseño y el monitoreo del entorno en un CPD son aspectos esenciales en cualquier estrategia de infraestructura tecnológica.

En cuanto al **suministro eléctrico y las comunicaciones**, pensemos que nuestro CPD no está aislado, sino que necesita ciertos servicios del exterior. Los principales son la alimentación eléctrica y las comunicaciones. En ambos casos conviene contratar con dos empresas distintas, de manera que un fallo en una compañía suministradora no nos impida seguir trabajando. El suministro eléctrico del CPD debería estar separado del que alimenta al resto de la empresa para evitar que un problema en cualquier otro punto del edificio afecte a los servidores.

Para los sistemas críticos, en los que la empresa no puede permitirse ninguna interrupción del servicio, deberemos instalar generadores eléctricos alimentados por combustible.



Fig. 8. Generador eléctrico.



WEB

Estrategias y mejores prácticas para proteger un CPD:

<https://cosglobalservices.com/actualidad/seguridad-cpd-estrategia-mejores-practicas>

2.4. Plan de recuperación de desastres

Tan importante como tomar medidas para proteger los equipos es tener en cuenta qué hacer cuando esas medidas fallan. **Todas las empresas deben tener documentado un plan de recuperación ante desastres** en el que se describa con el máximo detalle (en una crisis no hay tiempo para reflexionar) el protocolo de actuación ante una caída de cualquiera de los servicios que presta el CPD. Este plan debe ser actualizado cuando se efectúe un cambio en el CPD (nuevo servicio, nuevo equipo).

El plan debe incluir:

Hardware	Software	Datos
Qué modelos de máquinas tenemos instalados (tanto servidores como equipamiento de red), qué modelos alternativos podemos utilizar y cómo se instalarán (conexiones, configuración).	Qué sistema operativo y qué aplicaciones están instalados, con el número de versión actualizado y todas las opciones de configuración (permisos, usuarios, etc.).	Qué sistemas de almacenamiento utilizamos (discos locales, armario de discos), con qué configuración y cómo se efectúa el respaldo de datos (copias de seguridad).

2 CASO PRÁCTICO



PROTEGIENDO NUESTRO CPD

Una empresa de tecnología está construyendo un nuevo CPD y te ha contratado como consultor para garantizar que las medidas de seguridad física sean adecuadas. Tu tarea es evaluar la situación y proponer soluciones para la ubicación, el control de acceso, las condiciones ambientales y el plan de recuperación ante desastres.

Parte 1. Relacionar los conceptos con las definiciones

Asocia cada concepto con su definición correspondiente:

- » Ubicación óptima del CPD.
- » Control biométrico de accesos.
- » Pasillos fríos y calientes.
- » Generadores eléctricos.
- » Plan de recuperación ante desastres.

Definiciones:

- » Método que organiza los racks de servidores en filas alternas para optimizar la distribución del aire frío y caliente.
- » Documento detallado que describe las acciones por realizar ante una caída de los servicios del CPD.
- » Uso de tecnologías como lectores de huellas dactilares o escáneres de retina para verificar la identidad del personal autorizado.
- » Elementos redundantes alimentados por combustible que garantizan la continuidad del suministro eléctrico en caso de fallos externos.
- » Zona seleccionada para evitar los riesgos naturales y la proximidad a áreas peligrosas, como ríos o instalaciones de gases inflamables.

Parte 2. Ordenar los pasos en una secuencia lógica

Ordena los pasos para instalar y garantizar la seguridad física del CPD:

- » Instalar detectores de humo y sistemas de extinción de incendios.
- » Diseñar un plan de recuperación ante desastres.
- » Construir un falso suelo y un falso techo para facilitar el cableado y la ventilación.
- » Evaluar posibles ubicaciones considerando los riesgos naturales y la proximidad a zonas peligrosas.
- » Implementar un sistema de videovigilancia y control biométrico de accesos.

03 SAI

IMPORTANTE

La **corriente eléctrica** es vital en cualquier ordenador, y más en un centro de procesamiento de datos. En un CPD nunca debe faltar un SAI (sistema de alimentación ininterrumpida), que consiste en un conjunto de baterías que alimentan una instalación eléctrica (en nuestro caso, equipos informáticos).

En caso de corte de la corriente, los equipos conectados al SAI siguen funcionando porque consiguen electricidad de las baterías. La capacidad de estas baterías es reducida y depende del SAI elegido y del consumo de los equipos, aunque el mínimo garantizado suele ser diez minutos. Este es el factor más importante a la hora de adquirir un SAI: cuántos vatios consumen los equipos que debe proteger y durante cuánto tiempo necesitamos que los proteja.

Al igual que ocurría con los equipos de climatización, en este caso también conviene, si el presupuesto lo permite, **aplicar redundancia e instalar un doble juego de equipos SAI**, para estar cubiertos en caso de que uno fallara. Esto es posible gracias a que la mayoría de los servidores vienen con doble fuente de alimentación, por lo que solo habría que conectar cada una de las dos fuentes a cada SAI.

Cuando ocurre un **corte de luz**, el SAI procede de esta manera:

1. Espera unos instantes por si el corte ha sido puntual y el suministro se recupera inmediatamente por sí solo.
2. Si no es así, ejecuta una parada ordenada de los equipos conectados al SAI. Siempre es mejor solicitar una parada al sistema operativo y las aplicaciones que ejecuta que perder la corriente y confiar en que no se genere ninguna inconsistencia.

Conectar los equipos al SAI tiene otras **ventajas**:

- » Estos sistemas suelen llevar un estabilizador de corriente que elimina los picos, que también pueden ser muy dañinos.
- » En algunos SAI, también se incluye una entrada y salida de cable telefónico, que sirve para proteger nuestra conexión, porque las comunicaciones por línea telefónica también utilizan corriente eléctrica, luego también estamos expuestos a picos de tensión.



Fig. 9. SAI.

3.1. Tipos de SAI

En el mercado, encontramos básicamente dos tipos de SAI: los SAI online y los SAI fuera de línea u offline.

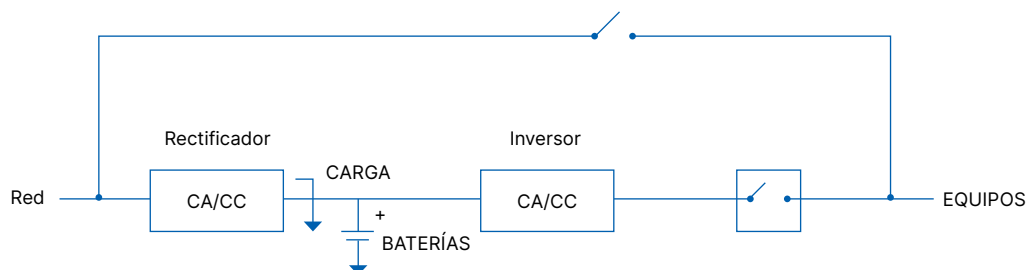
Un SAI fuera de línea alimenta el equipo que lleva conectado haciendo llegar directamente la señal de la red eléctrica. En el momento en que detecta un problema, muy rápidamente (en menos de cinco milisegundos), pasa a alimentar el equipo con la señal eléctrica que él mismo produce.

Por el contrario, un SAI en línea siempre alimenta el equipamiento conectado con la señal eléctrica generada por la **batería interna** y, mientras tanto, recarga continuamente esta batería con la señal que le llega de la red eléctrica. Esto permite que no haya latencia en la conmutación entre las fuentes de la señal eléctrica, y posibilita que la señal que ofrece el SAI sea muy estable.

Los SAI fuera de línea son **más baratos** y por eso son los más utilizados por usuarios particulares o pequeñas empresas. Los SAI en línea son más caros, pero, como nos aseguran una señal eléctrica muy estable, se usan con equipamientos en los que la estabilidad de la señal puede ser un factor crítico, como servidores, equipos de electromedicina, equipamientos de entidades bancarias, etc.

A. SAI fuera de línea

Un **SAI fuera de línea** es el circuito en el que vemos cómo la corriente eléctrica fluye por la línea continua directamente de la señal de la red eléctrica; en caso de alguna interrupción en el suministro de corriente, la batería y el ondulator se activan para generar la señal eléctrica.



Esquema 1. SAI offline.

En este tipo de SAI, la señal eléctrica llega **directamente desde la red eléctrica**. En el momento en que existe alguna interrupción en el suministro eléctrico, la batería y el ondulator se activan para continuar suministrando la señal eléctrica. Durante los breves momentos (milisegundos) en que se realiza el cambio entre la señal eléctrica proveniente de la red eléctrica y la señal proveniente de la batería, se produce una alteración en la señal que el SAI suministra. Esta es la mayor desventaja de esta clase de SAI. Por eso, cuanto más pequeño es este tiempo, de mayor calidad se considera el SAI.

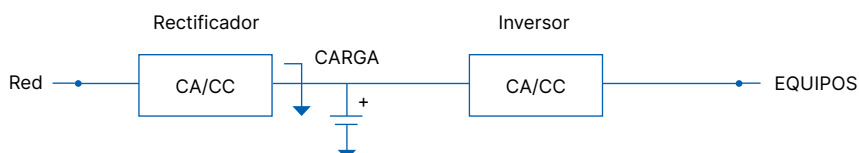
Los SAI fuera de línea proporcionan alimentación con la señal de la red eléctrica y, cuando hay un corte de corriente, proporcionan esa alimentación **con sus baterías internas**. Esto provoca una pequeña alteración de la señal de salida en el momento del cambio. El tiempo de duración de esta alteración se llama tiempo de transferencia.

Un SAI típico tiene un **tiempo de transferencia de unos 4 ms (milisegundos)**. Teniendo en cuenta que la mayoría de los ordenadores toleran un tiempo de transferencia de unos 100 ms, parecería que con un SAI de este tipo ya podemos quedarnos tranquilos. Sin embargo, esto no es exactamente así, pues, aunque nuestro ordenador siga funcionando, las alteraciones en las señales durante el tiempo de transferencia pueden provocar daños en los circuitos y, por tanto, cuanto más lo minimicemos, mejor. Por eso, a la hora de elegir un SAI, deberemos tener en cuenta como factor primordial el tiempo de transferencia.

Otras características que hay que tener en cuenta son las **funcionalidades adicionales** que nos ofrezca el SAI. Muchos SAI incorporan, por ejemplo, acondicionadores de línea o supresores de crestas. Todo lo que nos pueda asegurar una mayor estabilidad y una mejor calidad de la señal será un valor añadido de nuestro SAI.

B. SAI online

Un **SAI en línea (online)** suministra siempre la señal eléctrica desde sus baterías y, con ello, consigue evitar el tiempo de transferencia y dar una señal sin alteraciones de forma continuada.



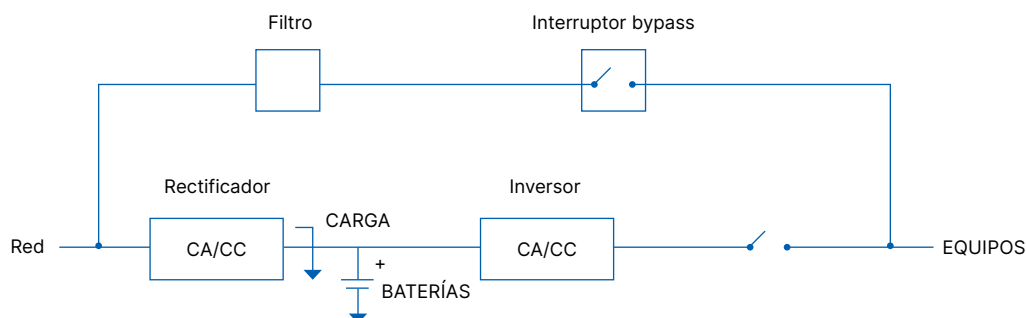
Esquema 2. SAI online.

Como las baterías dan corriente continua, es necesario un **ondulador** para convertir esta señal en corriente alterna. También podemos ver cómo las baterías se cargan constantemente con la señal eléctrica de la red. En caso de una cresta en la señal de entrada, la corriente seguirá un camino alternativo (camino punteado) y pasará por un supresor de crestas y un filtro. Así se evitarán daños al SAI.

Sin embargo, los SAI en línea también tienen algunas desventajas: como su diseño es más complejo, son más caros y, para dar permanentemente señal de su batería y transformarla con el ondulador, estos dispositivos deben consumir más energía, y generan más calor.

C. SAI inline

Existe un tipo híbrido de SAI, conocido como **SAI inline**. Estos SAI incorporan más funcionalidades que los SAI offline; por ejemplo, disponen de supresión de crestas de señal, o de filtrado de ruido eléctrico y compensación de voltaje. Además, tienen una respuesta más rápida a los cortes de corriente y por eso se los considera superiores a los SAI offline, pero no son de tanta calidad como los SAI online, que, como hemos visto, no sufren latencia por conmutación (tiempo de transferencia).



Esquema 3. SAI inline.

TIPO DE SAI	VENTAJAS	DESVENTAJAS
SAI offline (fuera de línea)	Económico y accesible para pequeñas empresas y usuarios domésticos.	Tiene un tiempo de transferencia (milisegundos sin suministro eléctrico durante el cambio a la batería).
	Consumo energético reducido.	La señal eléctrica puede sufrir alteraciones al cambiar de fuente de alimentación.
	Fácil instalación y mantenimiento.	Menos adecuado para equipos críticos.
SAI online (en línea)	Proporciona una señal eléctrica estable sin interrupciones.	Mayor coste en comparación con los modelos offline.
	No tiene tiempo de transferencia.	Mayor consumo energético y generación de calor.
	Ideal para servidores, equipos médicos y sistemas bancarios.	Requiere un sistema de refrigeración adecuado.
SAI inline (línea interactiva)	Mejor que los SAI offline en cuanto a estabilidad de la señal.	Aunque es superior al SAI offline, sigue teniendo algo de tiempo de transferencia.
	Reduce el tiempo de transferencia.	No alcanza la estabilidad del SAI online.
	Puede incorporar protección contra picos de voltaje y filtrado de ruido eléctrico.	Mayor coste que un SAI offline.

Tabla 1. Ventajas y desventajas de cada tipo de SAI.

3.2. Monitorización

Cuando tenemos un SAI confiamos en que funciona correctamente y que responderá cuando su intervención sea necesaria. No obstante, conviene revisar regularmente el estado del SAI. Estos equipos suelen incorporar unos indicadores luminosos en el frontal.



Fig. 10. Parte frontal del SAI.

Se muestra si está cargando o descargando las baterías, el porcentaje de batería restante, etc. Sin embargo, es una **información puntual y solo disponible si se está delante del equipo**. Para mejorar su gestión, los SAI suelen incorporar un puerto de conexión con un ordenador.

En ese ordenador instalaremos el software adecuado para comunicarse con el SAI y conocer no solo el estado actual, sino todas las veces que ha operado en el pasado reciente. Por supuesto, ese ordenador debe estar protegido, ya sea por este mismo SAI o por cualquier otro.

3.3. Triggers

El software del SAI, además de la monitorización, incluye la **configuración de los comandos** para responder ante un corte de corriente. En general, la respuesta consistirá en realizar la parada ordenada de los equipos protegidos.

Las elecciones principales son:

- » Cuándo hacerlo: en un instante concreto (cuando se alcance el battery backup time) o cuando detecte que la carga de la batería está baja.
- » Qué hacer con el sistema: suspenderlo o apagarlo.
- » Qué comando ejecutar antes de empezar el apagado (run command file before shutdown).

En este apartado aprovecharemos para apagar las otras máquinas conectadas a este SAI.

Además de la parada, se puede configurar un aviso por correo a los administradores del sistema.



¿SABÍAS QUE...?

La capacidad de un SAI se suele medir en **voltiamperios (VA)** y está relacionada con el consumo eléctrico en vatios (W). En general, las fuentes de alimentación utilizan un factor 0,6, de manera que un SAI de 1000 VA solo puede alimentar equipos de hasta 600 W.

3.4. Mantenimiento

Las baterías **se desgastan con el tiempo** y ofrecen cada vez menos rendimiento. El software del SAI nos ayuda en este aspecto, ya que permite lanzar determinadas pruebas para comprobar la degradación actual de las baterías. Si el rendimiento no es suficiente para garantizar la parada ordenada de los equipos protegidos, debemos cambiar las baterías, para lo cual acudiremos al personal especializado, porque las baterías utilizan componentes químicos muy peligrosos. El SAI incluye operaciones automáticas de descarga controlada, que alargan la vida de las baterías.

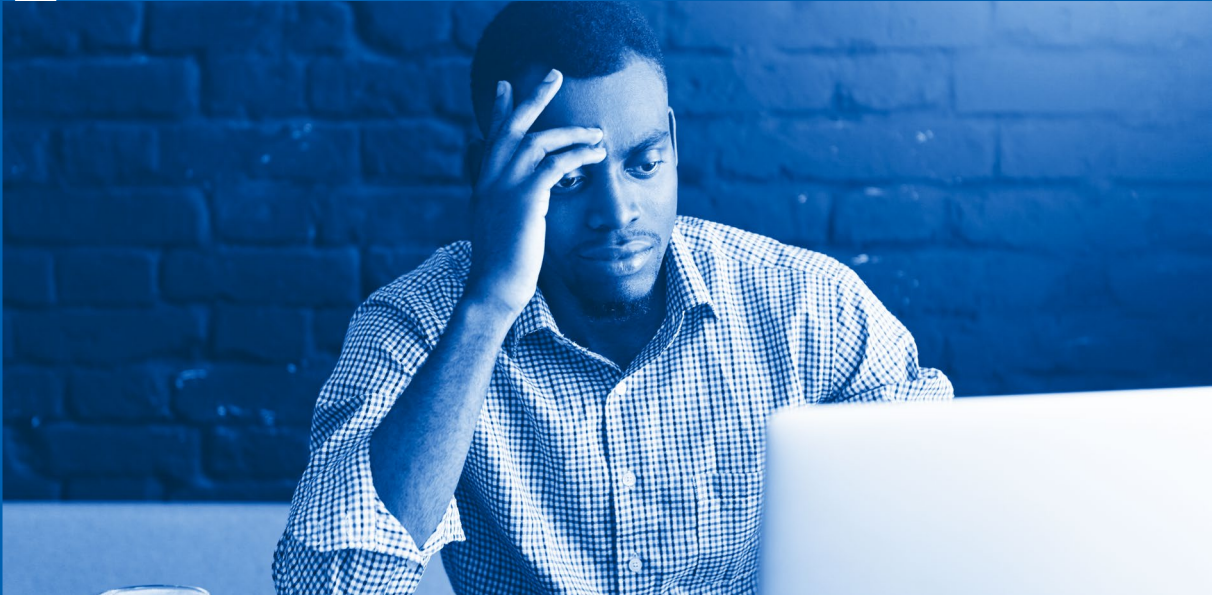
Como hemos visto, la operación de cambio de las baterías será relativamente sencilla en un SAI de tipo stand-by, porque mientras tanto los equipos seguirán alimentados; sin embargo, en un SAI online perderemos la alimentación, por lo que será necesario detener los equipos. Este aspecto puede ser crítico en una empresa que no pueda permitirse ninguna parada.

Los SAI empresariales suelen adoptar una **configuración modular**, es decir, que no utilizan pocas baterías grandes, sino muchas baterías pequeñas. Con este diseño podemos reemplazar fácilmente una batería sin afectar demasiado a la carga total ofrecida por el equipo y, a la vez, conseguimos escalabilidad: el cliente compra un bastidor con capacidad para alojar muchas baterías y lo va rellenando según aumenta el número de equipos protegidos.



Fig. 11. Bastidor con múltiples baterías.

3 CASO PRÁCTICO



SAI EN UNA EMPRESA DE DISEÑO GRÁFICO

La empresa de diseño gráfico Visual Creators tiene un pequeño CPD que aloja servidores esenciales para almacenar proyectos y gestionar aplicaciones críticas. Recientemente, han experimentado problemas eléctricos en su zona debido a tormentas frecuentes. El gerente de TI, preocupado por la continuidad del servicio, solicita al equipo técnico analizar la instalación de un sistema SAI para proteger sus equipos. La empresa cuenta con un presupuesto limitado y busca la solución más eficiente.

- » Lee con atención las necesidades de la empresa y responde las preguntas.
- » Evalúa los factores técnicos y económicos que influyen en la elección de un SAI.
- » Proporciona argumentos justificados basados en la información proporcionada.

Problemas planteados:

- » Evaluación de necesidades.
- » Los equipos que deben protegerse son:
 - 3 servidores, cada uno con un consumo de 300 W.
 - Un router y un switch, con un consumo combinado de 100 W.

Preguntas:

1. ¿Qué capacidad mínima en VA debería tener el SAI considerando el factor de corrección 0,6? Explica paso a paso cómo calcular la capacidad mínima del SAI considerando el factor de corrección.

2. Dada la naturaleza crítica de los servidores y el presupuesto limitado, la empresa debe elegir entre un SAI offline o un SAI online. ¿Cuál recomendarías? Justifica la elección teniendo en cuenta el presupuesto y la estabilidad eléctrica necesaria.
3. Para garantizar que el sistema responda adecuadamente durante un fallo eléctrico, se debe configurar el software de monitorización del SAI. ¿Qué tres configuraciones principales recomendarías para los triggers y por qué? Detalla las configuraciones principales de triggers y sus razones.
4. La empresa planea agregar más equipos en el futuro. ¿Qué características adicionales debe tener el SAI para garantizar que pueda escalar con las necesidades de la empresa? Describe las características del SAI necesarias para soportar el crecimiento futuro.

04 Seguridad lógica

4.1. Política de seguridad basada en listas de control de acceso (ACL)

DEFINICIÓN

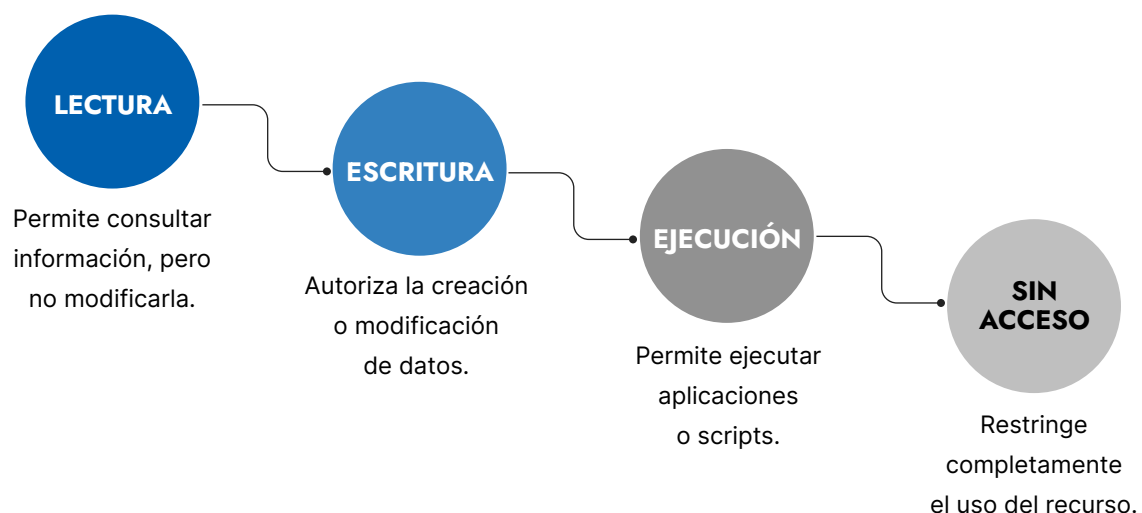
Dentro de un enfoque de seguridad pasiva, una **política basada en listas de control de acceso (ACL)** es una herramienta clave para gestionar y limitar quién puede interactuar con los recursos de un sistema o red. Esta política establece criterios claros sobre los niveles de acceso permitidos y las restricciones aplicables, contribuyendo a la protección de datos y sistemas críticos.

Las características propias de una política de seguridad basada en ACL son:

A. Definición de roles y privilegios

La política debe definir claramente los usuarios individuales y los grupos a los que pertenecen, asignando **privilegios específicos** según sus funciones dentro de la organización. Ejemplos de ello serían un grupo de administradores con acceso total y un grupo de empleados con acceso limitado a los recursos necesarios para sus tareas.

La asignación de permisos se realiza de manera granular, estableciendo diferentes niveles según las necesidades:



B. Control de recursos

Los **activos protegidos**, como archivos, bases de datos, aplicaciones, dispositivos de red y servidores, se identifican y clasifican según su nivel de sensibilidad. Cada recurso tiene reglas específicas que limitan el acceso según el usuario o grupo. Ejemplo: los datos financieros solo son accesibles por parte del departamento de contabilidad.

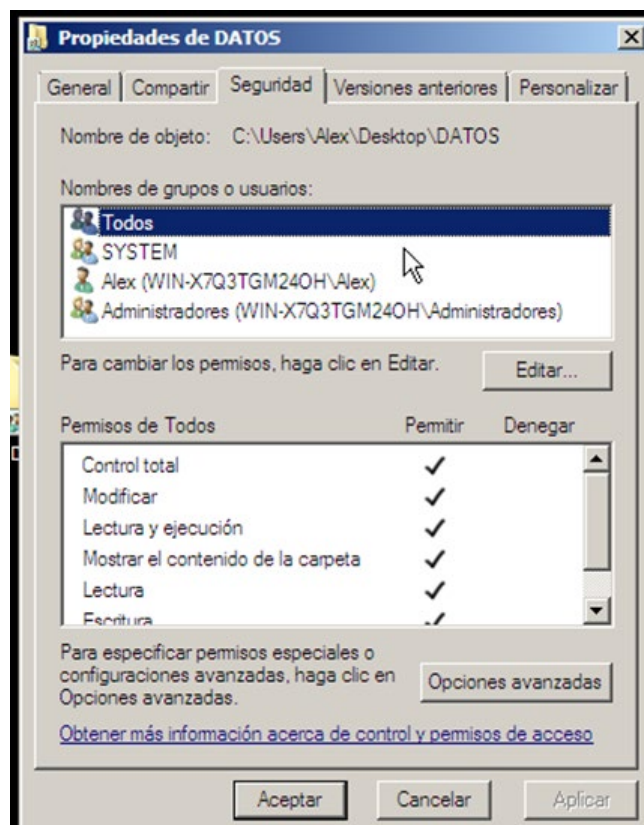
C. Principios fundamentales

- » Principio de menor privilegio: cada usuario o grupo debe contar únicamente con los permisos mínimos necesarios para realizar su trabajo.
- » Denegación predeterminada: todo acceso no explícitamente autorizado debe ser denegado por defecto, aplicando el enfoque deny by default.
- » Separación de funciones: las tareas críticas se distribuyen entre diferentes usuarios para evitar que una sola persona tenga control absoluto sobre un recurso.

D. Implementación técnica

La configuración de permisos se hará de la siguiente manera en los distintos sistemas operativos:

- » En sistemas **Windows**, se utilizan permisos NTFS para carpetas y archivos.



- » En **Linux/Unix**, se emplean comandos como **chmod** y **chown** junto con listas ACL extendidas para definir permisos avanzados. En esta imagen se puede observar cómo hay una lista de acceso que incluye al propietario del recurso «información», el grupo al que pertenece, y, en este caso, al grupo «dirección».

```

root@debian:/home# setfacl -R -m g:direccion:r informacion/
root@debian:/home# getfacl informacion
# file: informacion
# owner: root
# group: root
user::rwx
group::r-x
group:direccion:r--
mask::r-x
other::r-x

root@debian:/home# ls -al
total 40
drwxr-xr-x 10 root    root    4096 nov  4 00:06 .
drwxr-xr-x 21 root    root    4096 nov  3 17:01 ..
drwxr-xr-x  2 alumno1 alumno1 4096 nov  3 23:51 alumno1
drwxr-xr-x  2 alumno2 alumno2 4096 nov  3 23:52 alumno2
drwxr-xr-x  2 direccion1 direccion1 4096 nov  3 23:43 direccion1
drwxr-xr-x  2 direccion2 direccion2 4096 nov  3 23:44 direccion2
drwxr-xr-x  5 erik     erik    4096 nov  3 23:12 erik
drwxr-xr-x+  4 root    root    4096 nov  4 00:06 informacion
drwxr-xr-x  2 profesor1 profesor1 4096 nov  3 23:45 profesor1
drwxr-xr-x  2 profesor2 profesor2 4096 nov  3 23:48 profesor2
root@debian:/home#

```

Las listas de control de acceso en **dispositivos de red** como routers o switches se configuran para filtrar el tráfico no autorizado. Un ejemplo de ello es permitir conexiones HTTP desde una red interna mientras se bloquea el tráfico SSH desde direcciones IP no confiables.

E. Reglas y políticas de acceso

- » **Reglas explícitas:** se definen permisos específicos para usuarios, aplicaciones o dispositivos, asegurando que cada recurso esté protegido. Por ejemplo, un servidor de bases de datos de una compañía solo permite conexiones desde el departamento de TI durante el horario laboral.
- » **Políticas de acceso condicional:**
- **Horarios:** permitir el acceso únicamente durante las horas de trabajo.
 - **Ubicación:** permitir el acceso solo desde ciertas direcciones IP o ubicaciones físicas.

F. Auditorías y monitoreo

- » **Registro de actividades:** todas las acciones de acceso, ya sean permitidas o bloqueadas, deben registrarse en logs para su posterior análisis.
- » **Alertas automáticas:** el sistema debe generar notificaciones ante los intentos de acceso no autorizados o anomalías en el comportamiento.
- » **Revisión periódica:** es esencial auditar las ACL regularmente para asegurarse de que reflejan la estructura actual de la organización y sus necesidades.

4.2. Política de contraseñas

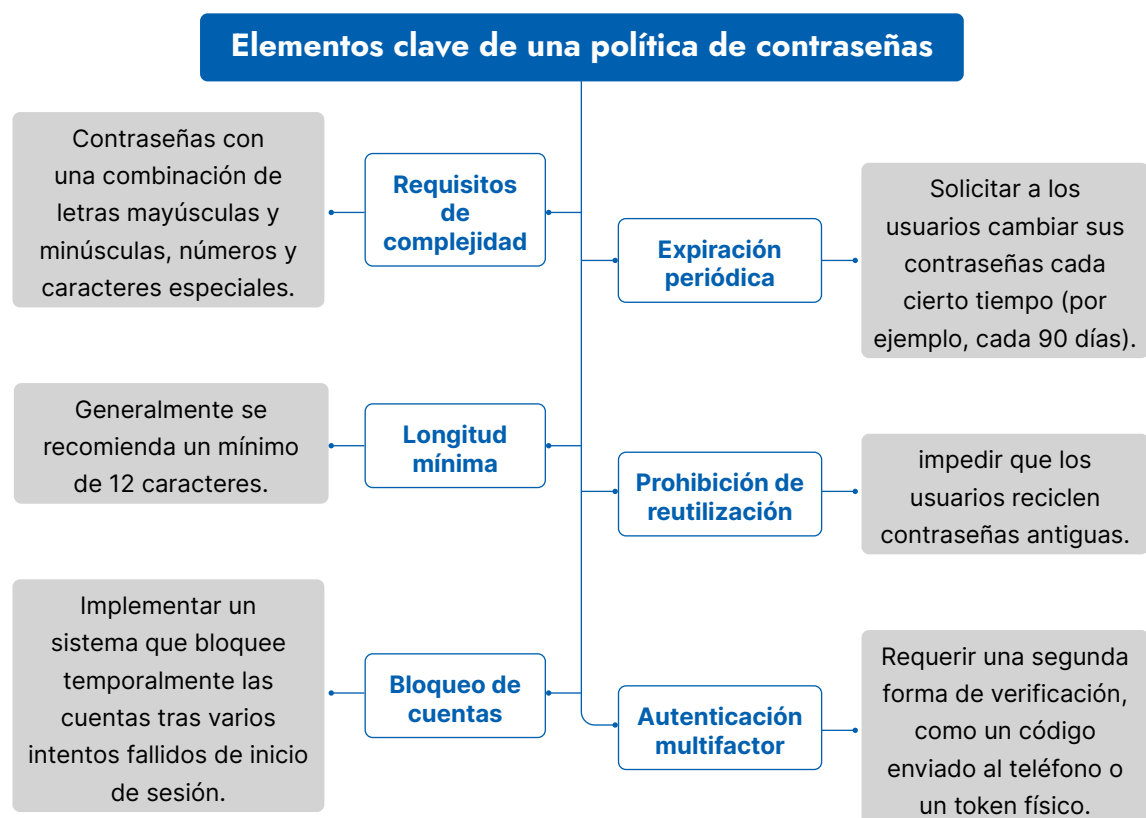
En el ámbito de la seguridad lógica, las contraseñas representan una de las **primeras líneas de defensa** contra los accesos no autorizados a los sistemas, las aplicaciones y los datos. Establecer una política de contraseñas sólida y bien definida es fundamental para proteger la confidencialidad, la integridad y la disponibilidad de la información en una organización. Cuenta con las siguientes ventajas:

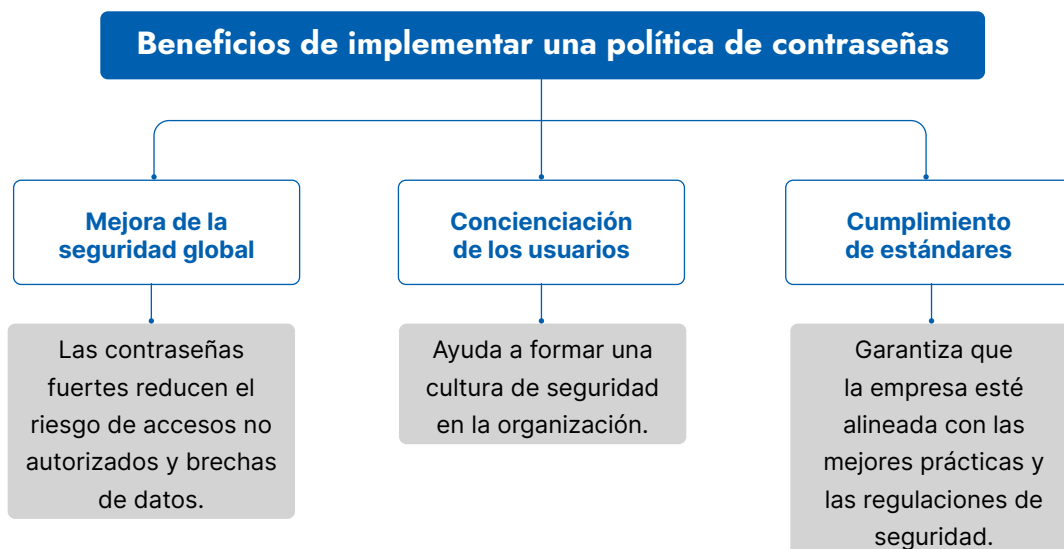
- » **Protección frente a accesos no autorizados:** las contraseñas actúan como una barrera que impide que personas no autorizadas accedan a los sistemas o recursos sensibles. Sin una política que regule su uso, las contraseñas pueden ser débiles, fáciles de adivinar o repetidas en múltiples cuentas, lo que incrementa el riesgo de accesos indebidos.
- » **Una política de contraseñas ayuda a:**
 - Establecer requisitos mínimos de fortaleza, como la longitud, la complejidad y el uso de caracteres especiales.
 - Reducir la probabilidad de que las contraseñas sean vulnerables a ataques de fuerza bruta o adivinación.
- » **Mitigación de ataques cibernéticos:** los ataques más comunes, como el phishing, el credential stuffing y el ataque de fuerza bruta, explotan contraseñas débiles o reutilizadas. Una política de contraseñas puede mitigar estos riesgos al requerir:
 - Contraseñas únicas para cada sistema, evitando que un atacante utilice credenciales robadas de un sistema en otros.
 - Cambios periódicos de contraseñas, limitando la exposición en caso de filtraciones.
- » **Promoción de buenas prácticas entre los usuarios:** sin una política clara, los usuarios tienden a priorizar la conveniencia sobre la seguridad, eligiendo contraseñas fáciles de recordar (como 123456 o password) o reutilizando la misma en varias cuentas. Una política de contraseñas establece estándares que promueven prácticas seguras, como:
 - Uso de gestores de contraseñas para almacenar y generar contraseñas complejas.
 - Formación en la creación de contraseñas seguras y en cómo evitar errores comunes (como anotar contraseñas en lugares accesibles).

» **Cumplimiento normativo y regulaciones:** muchas leyes y estándares de seguridad, como la LOPD (Ley Orgánica de Protección de Datos) o la ISO 27001, exigen medidas adecuadas para proteger los datos, incluyendo políticas de contraseñas robustas. Cumplir con estos requisitos no solo protege la información, sino que también evita multas y sanciones.

» **Reducción del impacto de errores humanos:** el comportamiento humano es uno de los puntos más débiles en la seguridad informática. Una política de contraseñas bien implementada puede minimizar estos riesgos al:

- Prohibir prácticas inseguras, como compartir contraseñas entre compañeros de trabajo.
- Requerir la autenticación multifactor (MFA) como complemento a las contraseñas, añadiendo una capa adicional de seguridad frente a errores o contraseñas comprometidas.





4.3. Utilización de sistemas biométricos

Los sistemas biométricos representan **una de las tecnologías más avanzadas** para la autenticación y el control de accesos, al utilizar características únicas e intransferibles del cuerpo humano, como las huellas dactilares, el reconocimiento facial o el escáner de iris. Debido a su precisión, su conveniencia y su seguridad, estas tecnologías ofrecen numerosas ventajas frente a los métodos tradicionales, como las contraseñas o las tarjetas de acceso.

A. Alta seguridad

Los sistemas biométricos proporcionan un nivel de seguridad superior al de las contraseñas o las tarjetas, ya que utilizan características físicas o comportamentales únicas de cada individuo. Esto reduce significativamente el riesgo de:

- » **Suplantación de identidad:** es extremadamente difícil replicar o falsificar rasgos biométricos como huellas dactilares o patrones de iris.
- » **Accesos no autorizados:** solo las personas autorizadas, verificadas mediante sus rasgos únicos, pueden acceder a los recursos o instalaciones protegidas.

B. Reducción de problemas asociados a las contraseñas

Los sistemas biométricos eliminan las debilidades inherentes a los métodos tradicionales de autenticación, como:

- » La posibilidad de olvidar contraseñas.
- » El uso de contraseñas débiles o reutilizadas.
- » El robo de credenciales a través de phishing o ataques similares.

C. Conveniencia y rapidez

La autenticación biométrica es rápida y sencilla para los usuarios por estas características:

- » Sin necesidad de recordar credenciales: los usuarios no tienen que recordar contraseñas ni llevar consigo tarjetas o tokens.
- » Procesos más ágiles: la verificación biométrica suele completarse en cuestión de segundos, reduciendo tiempos en comparación con otros métodos.

D. Dificultad para transferir o compartir

A diferencia de las contraseñas o las tarjetas, las características biométricas no pueden ser prestadas, compartidas o transferidas entre usuarios. Esto asegura que solo la persona autorizada pueda acceder al sistema o lugar protegido.

E. Compatibilidad con autenticación multifactor

Los sistemas biométricos pueden integrarse fácilmente con otras capas de autenticación, como contraseñas o tokens, en esquemas de autenticación multifactor (MFA). Esto refuerza aún más la seguridad al combinar algo que el usuario sabe (contraseña), algo que tiene (token) y algo que es (biometría).

F. Registro y auditoría fiables

Los sistemas biométricos generan registros detallados y precisos de los accesos realizados:

- » **Trazabilidad:** se puede identificar con exactitud quién accedió a un recurso o instalación y en qué momento.
- » **Prevención de disputas:** los registros biométricos eliminan dudas sobre la identidad del usuario en caso de auditorías o investigaciones.

G. Longevidad y durabilidad

Los dispositivos biométricos, como lectores de huellas o cámaras para reconocimiento facial, son generalmente duraderos y requieren poco mantenimiento. Su implementación inicial puede ser más costosa, pero la inversión se compensa a largo plazo al reducir la necesidad de gestionar contraseñas, emitir tarjetas o reemplazar tokens.

H. Aplicaciones versátiles

Los sistemas biométricos pueden utilizarse en una amplia variedad de contextos, como:

- » **Control de accesos físicos:** restricción de entrada a edificios, salas de servidores o áreas restringidas.
- » **Autenticación digital:** acceso a sistemas, aplicaciones y datos sensibles.
- » **Pagos y transacciones financieras:** autenticación biométrica para pagos seguros, como el uso de huellas dactilares en dispositivos móviles.

I. Adaptación a contextos modernos

La biometría se integra perfectamente en entornos tecnológicos actuales, como los dispositivos móviles, los sistemas de videovigilancia inteligentes o las plataformas de trabajo remoto, adaptándose a las necesidades cambiantes de seguridad y accesibilidad.



WEB

- » Beneficios de la biometría: <https://www.globalsign.com/es/blog/7-beneficios-que-ofrece-la-biometria-la-seguridad>
- » AEPD, control de presencia biométrico: <https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-aepd-publica-una-guia-sobre-la-utilizacion-de-datos>



VIDEOLAB

Para consultar el siguiente vídeo sobre las **ACL en entorno Windows y su auditoría**, escanea el código QR o [pulsa aquí](#).

Veremos cómo se crea una lista de control de acceso en Windows. Aprenderemos a otorgar y retirar permisos de acceso a distintos tipos de roles. Además, descubriremos el proceso de auditoría que se debe llevar a cabo para controlar el uso de estos recursos.

4 CASO PRÁCTICO



POLÍTICA DE SEGURIDAD BASADA EN LISTAS DE CONTROL DE ACCESO

Una pequeña empresa llamada InnovaTec, que desarrolla software, necesita proteger sus recursos digitales. Actualmente, no existen restricciones claras sobre quién puede acceder a los servidores y las bases de datos, lo que pone en riesgo la información. El equipo de TI decide implementar una política basada en listas de control de acceso (ACL) para controlar quién puede acceder a qué recursos y con qué permisos.

Cuenta con los siguientes recursos disponibles:

- » Servidor de desarrollo (IP: 192.168.1.10).
- » Servidor de producción (IP: 192.168.1.20).
- » Base de datos financiera (IP: 192.168.1.30).

Estos son sus usuarios y roles:

- » **Administradores:** tienen acceso total a todos los recursos.
- » **Desarrolladores:** solo pueden acceder al servidor de desarrollo para leer y escribir.
- » **Contabilidad:** solo pueden acceder a la base de datos financiera.

Describe los pasos para implementar las listas de control de acceso.

Solucionario casos prácticos

1

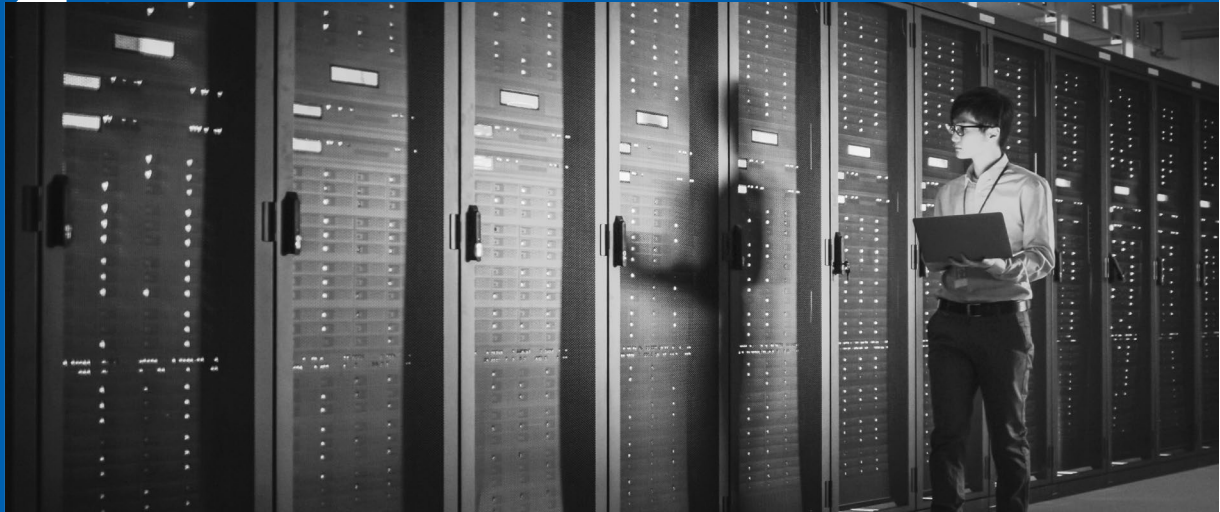
SOLUCIÓN CASO PRÁCTICO



IDENTIFICACIÓN DE TAREAS PROPIAS DE SEGURIDAD FÍSICA Y SEGURIDAD LÓGICA

SEGURIDAD FÍSICA	SEGURIDAD LÓGICA
Sistema de climatización	Permisos de carpetas compartidas
Protección de equipos con SAI	Antivirus
Instalación de falso techo	Control de permisos por ACL
Protección contra incendios	Autenticación multifactor
Sistema de videovigilancia	Autenticación biométrica

2 SOLUCIÓN CASO PRÁCTICO



PROTEGIENDO NUESTRO CPD

Parte 1: Relacionar los conceptos con las definiciones

- » Ubicación óptima del CPD → Zona seleccionada para evitar los riesgos naturales y la proximidad a áreas peligrosas, como ríos o instalaciones de gases inflamables.
- » Control biométrico de accesos → Uso de tecnologías como los lectores de huellas dactilares o los escáneres de retina para verificar la identidad del personal autorizado.
- » Pasillos fríos y calientes → Método que organiza los racks de servidores en filas alternas para optimizar la distribución del aire frío y caliente.
- » Generadores eléctricos → Elementos redundantes alimentados por combustible que garantizan la continuidad del suministro eléctrico en caso de fallos externos.
- » Plan de recuperación ante desastres → Documento detallado que describe las acciones que hay que realizar ante una caída de los servicios del CPD.

Parte 2: Ordenar los pasos en una secuencia lógica

- » Evaluar posibles ubicaciones considerando los riesgos naturales y la proximidad a zonas peligrosas.
- » Construir un falso suelo y un falso techo para facilitar el cableado y la ventilación.
- » Instalar detectores de humo y sistemas de extinción de incendios.
- » Implementar un sistema de videovigilancia y control biométrico de accesos.
- » Diseñar un plan de recuperación ante desastres.

3 SOLUCIÓN CASO PRÁCTICO



SAI EN UNA EMPRESA DE DISEÑO GRÁFICO

1.

» Consumo total:

- 3 servidores $\times$ 300 W = 900 W.
- Router y switch = 100 W.
- Total: 900 W + 100 W = 1000 W.

» Capacidad en VA:

$$VA = \frac{\text{Consumo en W}}{\text{Factor de corrección}} = \frac{1000}{0,6} = 1,666,666$$

Se necesita un SAI con una capacidad mínima de 1700 VA para cubrir los equipos.

2.

La recomendación sería optar por un **SAI offline**.

Y ello debido a que es más económico, por lo que resulta ideal para empresas con presupuesto limitado. Además, es adecuado si el tiempo de transferencia (4 ms) no afecta gravemente a los equipos. Sin embargo, no elimina por completo las alteraciones de la señal durante el tiempo de transferencia y tiene menor estabilidad en comparación con un SAI online.

Dado que el presupuesto es limitado y que los equipos pueden tolerar tiempos de transferencia cortos, un SAI offline es la mejor opción económica.

3.

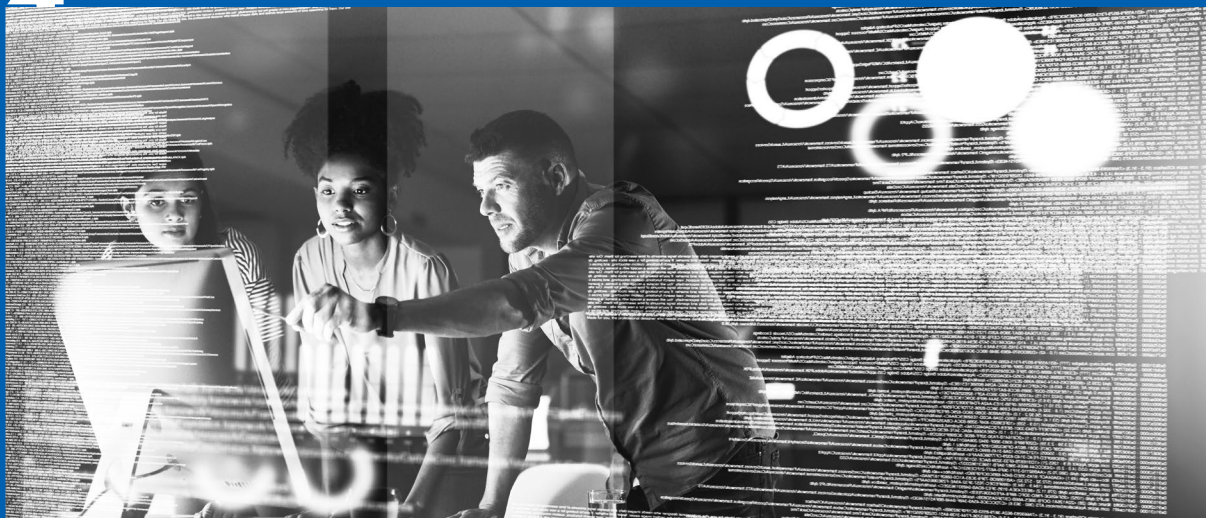
- » **Tiempo de batería restante:** configurar el software para realizar la parada ordenada cuando la batería alcance un nivel crítico (por ejemplo, el 20 %). Esto garantiza que los equipos se apaguen de manera segura antes de que la batería se agote.
- » **Ejecución de comandos previos al apagado:** configurar comandos para apagar de forma ordenada otros equipos conectados al SAI antes de iniciar la parada. Esto permite gestionar correctamente todos los equipos dependientes del SAI.
- » **Notificaciones automáticas:** configurar alertas por correo a los administradores cuando ocurra un corte eléctrico o un fallo en el sistema. Esto proporciona información inmediata para poder actuar rápidamente ante incidentes.

4.

- » **Diseño modular:** ofrece la posibilidad de añadir baterías adicionales según crezca el consumo eléctrico de la empresa.
- » **Soporte para mayor capacidad:** posibilita asegurarse de que el SAI pueda soportar cargas mayores mediante la instalación de módulos adicionales.
- » **Puertos de conexión:** permite incluir puertos para monitorear y controlar nuevos equipos conectados.

Un diseño escalable evita la necesidad de reemplazar el SAI en el futuro, reduciendo costes a largo plazo.

4 SOLUCIÓN CASO PRÁCTICO



POLÍTICA DE SEGURIDAD BASADA EN LISTAS DE CONTROL DE ACCESO

1. Identificar los roles y los recursos que se deben proteger.
2. Establecer reglas de acceso según los roles y recursos.
3. Configurar las ACL en los servidores y dispositivos de red.
4. Configurar logs para registrar los accesos y generar alertas.
5. Revisar periódicamente las ACL para adaptarlas a posibles cambios.

Enlaces de interés

AEPD control de presencia biométrico:

<https://www.aepd.es/prensa-y-comunicacion/notas-de-prensa/la-aepd-publica-una-guia-sobre-la-utilizacion-de-datos>

Beneficios de la biometría:

<https://www.globalsign.com/es/blog/7-beneficios-que-ofrece-la-biometria-la-seguridad>

Estrategias y mejores prácticas para proteger un CPD:

<https://cosglobalservices.com/actualidad/seguridad-cpd-estrategia-mejores-practicas>

Importancia de la seguridad de la información:

<https://www.incibe.es/empresas/blog/pasado-presente-y-futuro-de-la-seguridad-de-la-informacion>

Medidas implementadas por Microsoft para proteger sus centros de datos, incluyendo el uso de tarjetas de acceso y lectores biométricos supervisados a través de sistemas de alarma:

<https://learn.microsoft.com/es-es/compliance/assurance/assurance-datacenter-physical-access-security>

Glosario

- » **Listas de control de acceso o ACL (Access Control Lists):** Listas utilizadas para definir permisos específicos sobre los recursos, como archivos o redes, según los usuarios o grupos. Permiten gestionar quién puede leer, escribir, ejecutar o acceder a determinados elementos.
- » **Autenticación biométrica:** Método de verificación basado en características físicas únicas e intransferibles, como las huellas dactilares, el reconocimiento facial o el escáner de retina, para garantizar el acceso seguro a los sistemas o instalaciones.
- » **Autenticación multifactor (MFA):** Proceso de autenticación que requiere múltiples elementos para verificar la identidad de un usuario, combinando algo que sabe (contraseña), algo que tiene (token) y algo que es (biometría).
- » **Centro de procesamiento de datos (CPD):** Sala dedicada al alojamiento de servidores y dispositivos de red. Está diseñada para garantizar la protección física y lógica de los equipos y mantener unas condiciones ambientales óptimas.
- » **Climatización en CPD:** Control de la temperatura, la humedad y la calidad del aire en centros de procesamiento de datos para garantizar el correcto funcionamiento de los equipos. Incluye sistemas de refrigeración y deshumidificación.
- » **Confidencialidad:** Principio de seguridad que asegura que solo las personas o los sistemas autorizados puedan acceder a la información. Protege los datos sensibles contra accesos no autorizados.
- » **Disaster Recovery Plan (DRP):** Plan de recuperación ante desastres que detalla las acciones y procedimientos para restaurar los sistemas y servicios tras un fallo o incidente grave.
- » **Disponibilidad:** Garantía de que los datos y sistemas estén accesibles cuando se necesite, evitando interrupciones en los servicios esenciales.
- » **Integridad:** Principio que asegura que los datos no sean alterados de manera no autorizada o accidental, garantizando su precisión y su confiabilidad.
- » **LOPD (Ley Orgánica de Protección de Datos):** Norma española que regula el tratamiento y la protección de los datos personales, asegurando la privacidad y los derechos de los ciudadanos.

- » **Malware:** Software malicioso diseñado para causar daños, robar información o comprometer la seguridad de un sistema. Ejemplos: virus, ransomware y spyware.
- » **Pasillos fríos y calientes:** Diseño en CPD que organiza los racks de servidores en filas alternas para optimizar la entrada de aire frío y la extracción de aire caliente, mejorando la eficiencia del sistema de climatización.
- » **Principio de menor privilegio:** Regla de seguridad que establece que cada usuario o sistema debe tener únicamente los permisos necesarios para realizar sus tareas, reduciendo el riesgo de accesos indebidos.
- » **Ransomware:** Tipo de malware que secuestra datos o sistemas, exigiendo un pago a cambio de su liberación. Puede causar pérdidas económicas y operativas significativas.
- » **Seguridad física:** Conjunto de medidas destinadas a proteger los equipos, dispositivos y recursos informáticos contra daños físicos, robos, desastres naturales u otros riesgos.
- » **Seguridad lógica:** Medidas y configuraciones diseñadas para proteger los sistemas y datos informáticos frente a accesos no autorizados, alteraciones o pérdidas. Incluye contraseñas, cifrado y firewalls.
- » **Sistema de alimentación ininterrumpida (SAI) o Uninterruptible Power Supply (UPS):** Dispositivo que proporciona energía eléctrica temporal mediante baterías en caso de interrupciones en el suministro, asegurando el funcionamiento continuo de los equipos críticos.
- » **Spyware:** Programa malicioso diseñado para recopilar información confidencial de un sistema sin el conocimiento del usuario, como sus contraseñas o sus datos financieros.
- » **Tiempo de transferencia (en SAI):** Intervalo de tiempo que tarda un SAI en conmutar de la alimentación eléctrica convencional a su batería interna durante un fallo en el suministro eléctrico.

Bibliografía

Periáñez, F. Seguridad activa y pasiva. Manual de seguridad informática-I. FPgenred.:

https://www.fpgenred.es/Seguridad-Informatica-I/seguridad_activa_y_pasiva.html

Computerworld (2023). Seguridad informática activa vs seguridad informática pasiva: claves y diferencias.

<https://www.computerworld.es/article/2109797/seguridad-informatica-activa-vs-seguridad-informatica-pasiva-claves-y-diferencias.html>

Artículo de Ribesalat que describe las diferencias entre seguridad activa y pasiva en informática, destacando cómo la seguridad activa intenta prevenir ataques antes de que ocurran, mientras que la seguridad pasiva se centra en minimizar los daños una vez que se ha producido un incidente:

<https://ribesalat.com/diferencias-entre-la-seguridad-activa-y-la-seguridad-pasiva-en-informatica/>

UAX FP